

RAPORT DE CONSTATARE

RONOR — Sovereign Intelligence Operating Runtime

Audit tehnic de stare și securitate

Obiect	Infrastructura, codul și lanțul de trasabilitate al platformei RONOR
Perioada de examinare	24 august 2026, 18:00 – 25 august 2026, 07:00 (EEST)
Revizia de referință	44f379870be43b617c4838cba0f066c053ce2b1a (origin/main)
Depozit	github.com/Constantin1968/RONOR-
Gazde examinate	4 din 4 — DigitalOcean primar, Hetzner secundar, Contabo, bastion DO
Noduri de rețea	7 în tailnet, toate identificate
Solicitant	Constantin Liviu NITA
Clasificare	Intern — conține referințe la expuneri neremediate

Toate valorile din acest raport au fost măsurate prin sondare live, interogare de protocol cu porturi de control, și citire directă a codului sursă. Nicio valoare de secret nu este afișată. Nicio operațiune de scriere nu a fost efectuată pe depozit sau pe sistemele de producție.

1. Scopul și limitele auditului

1.1 Scop

Stabilirea stării reale, verificabile, a platformei RONOR la data auditului, pe patru axe:

- Infrastructura** — ce rulează, unde, din ce revizie, cu ce expunere de rețea
- Capabilitățile** — ce poate face codul, dovedit prin citirea sursei, nu prin documentație
- Trasabilitatea** — cine a scris ce, inclusiv atribuirea către agenți AI
- Securitatea** — expuneri, goluri de control, slăbiciuni de proces

1.2 Metodă

Fiecare constatare din acest raport are la bază o **măsurătoare directă**:

- sondare live prin Tailscale și SSH pe cele patru gazde
- interogare la nivel de protocol a porturilor, din rețea externă, **cu porturi de control** pentru eliminarea fals-pozitivelor
- citire integrală a codului sursă în `src/runtime/` (70 fișiere, 13.114 linii)
- analiză git pe toate cele 167 de commit-uri, 24 de ramuri remote, toate etichetele, `git fsck` pentru cod orfan
- inspecție `docker ps`, `docker network inspect`, `systemctl`, `ss -lntp`, `ufw status`, `iptables -S DOCKER` pe fiecare gazdă

Documentația proiectului nu a fost tratată ca sursă de adevăr, ci exclusiv ca ipoteză de verificat. În trei cazuri s-a dovedit falsă; acestea sunt marcate explicit în raport.

1.3 Constrângeri respectate

Constrângere	Respectată
Zero <code>merge</code> , <code>push</code> pe <code>main</code> , <code>release</code> sau <code>deploy</code>	Da — nicio operațiune de scriere pe depozit sau pe producție
Nicio valoare de secret afișată	Da — exclusiv lungime, permisiuni, proprietar, prefix de hash
Fără acces la consolele de vendor de pe IP rusesc	Da — tot accesul prin Tailscale/SSH; nicio consolă Hetzner, Contabo, DigitalOcean, OpenAI sau Anthropic accesată
Nimic instalat pe laptop	Da — laptopul folosit exclusiv ca punte de control

1.4 Limite ale auditului — ce NU a fost verificat

- Corelarea cheilor API cu conturile și proiectele de vendor.** Cheile există în fișierele de mediu; asocierea lor cu cele două conturi ChatGPT Pro și cele trei proiecte OpenAI Developer Platform **nu este verificabilă din infrastructură** și necesită acces la consola OpenAI, exclus prin constrângerea 1.3.
- Șapte din zece furnizori de inteligență netestați live.** Verificați prin apel real: Qwen/DashScope, Ollama/Contabo, DigitalOcean Inference. Netestați: Anthropic, Gemini, DeepSeek, Perplexity, OpenAI, Kimi, xAI — chei prezente, funcționalitate neconfirmată.
- Conținutul bazelor de date.** Au fost enumerate tabelele; nu au fost citite date.
- Nodul `do-bastion-agent`** — accesibil în rețea și caracterizat din exterior, dar **fără acces la shell**: nicio cheie din estate nu este acceptată. Caracterizarea lui se bazează pe amprentare de porturi și răspuns HTTP.

2. Sinteză executivă

2.1 Constatarea principală

Platforma nu suferă de deficit de capabilitate, ci de deficit de coerență.

Sistemul examinat este substanțial și, în părți importante, de calitate ridicată: 4 gazde, 69 de containere active, 33.709 linii de TypeScript cu 1.084 de teste care trec integral și zero erori de tip. Nicio muncă nu a fost pierdută: 22 din 24 de ramuri remote sunt deja integrate în `main`, iar depozitul nu conține stash-uri, commit-uri orfane sau fișiere netracked.

Problema este de altă natură. **Trei generații de cod rulează simultan, iar cea mai avansată nu este desfășurată deloc.** Documentația s-a oprit pe 3 august. Versionarea are patru surse contradictorii și scade în timp. Infrastructura care face muncă reală nu este nici versionată, nici testată, nici documentată. Iar mecanismele de control cele mai elaborate — pașapoarte de agent, poarta MI9, lanț de audit — nu sunt conectate la sistemele care execută efectiv comenzi.

2.2 Constatări clasificate pe severitate

#	Constatare	Severitate	Efort de remediere
C-01	Server Whisper public, complet neautentificat, pe Contabo	Critică	10 min
C-02	PostgreSQL 16 accesibil public pe DigitalOcean	Critică	10 min
C-03	Ocolirea ufw de către Docker este sistemică, nu incidentală	Critică	1 h
C-04	Execuție de shell neguvernată pe două gazde	Înaltă	1–2 zile
C-05	Cod desfășurat fără trasabilitate git	Înaltă	30 min
C-06	Producția rulează o ramură de fix, nu <code>main</code>	Înaltă	verificare
C-07	Modul cu răspunsuri simulate montat pe API-ul public	Înaltă	30 min
C-08	Scanarea de secrete în CI este neblocantă	Înaltă	5 min
C-09	„Net verified gain” nu se calculează — blochează pilotul OSaaS	Medie	2–4 h
C-10	Versionare fără sursă unică de adevăr, cu numerotare descrescătoare	Medie	1 h
C-11	Trasabilitatea contribuției AI nu există în artefacte	Medie	ireversibilă parțial
C-12	Stiva de automatizare rulează dublu, din revizii diferite	Medie	1 h
C-13	Nod în tailnet fără acces și fără funcție (<code>do-bastion-agent</code>)	Medie	15 min
C-14	Documentație stagnantă — 43 din 47 de fișiere	Medie	1 zi
C-15	ESLint nu rulează niciodată în CI	Scăzută	15 min
C-16	825 de linii de cod orfan; 2.140 de linii testate dar nemontate	Scăzută	2 h
C-17	Coliziuni de nomenclatură și trei orchestratoare nedelimitate	Scăzută	1 zi
C-18	Absența <code>.mailmap</code> — 10 identități pentru 2 persoane	Scăzută	15 min

3. Constatări de securitate

C-01 — Server Whisper public și neautentificat (CRITICĂ)

Situația de fapt. Containerul `ronor-whisper` (imagine `fedirz/faster-whisper-server:latest-cpu`), activ de 2 săptămâni pe gazda Contabo `vmi3488431`, publică portul 8200 pe 0.0.0.0. Gazda are IP public 169.58.129.223.

Verificare. Interogare de pe rețea externă, cu porturi de control:

Cale	Răspuns
<code>http://169.58.129.223:8200/health</code>	HTTP 200, corp OK
<code>http://169.58.129.223:8200/v1/models</code>	HTTP 200 — expune <code>Systran/faster-whisper-small</code> cu peste 90 de limbi

Cale	Răspuns
<code>http://169.58.129.223:8200/docs</code>	HTTP 200 — interfață Swagger deschisă
<code>:11434</code> (Ollama)	000 — filtrat corect de ufw
<code>:9999, :8201</code> (control)	000 — filtrat

Porturile de control confirmă că rezultatele pozitive nu sunt artefacte de rețea.

Impact. Orice terț poate consuma nelimitat cele 24 de vCPU ale gazdei pentru transcriere audio, fără nicio credențială. Suprafața include încărcarea de fișiere arbitrară într-un proces de decodare media. Documentația API este publicată integral. Nu există autentificare pe niciun endpoint.

Cauză. `ufw` nu conține nicio regulă pentru 8200. Expunerea provine din `docker-proxy`, care inserează reguli în lanțul `iptables DOCKER`, evaluat **înaintea** lanțurilor gestionate de `ufw`.

Remediere. În definiția `compose` a serviciului, `0.0.0.0:8200:8000 → 127.0.0.1:8200:8000`, apoi repornirea containerului. Accesul legitim se face prin Tailscale, ca la Ollama.

C-02 — PostgreSQL 16 accesibil din internetul public (CRITICĂ)

Situația de fapt. Containerul `ronor-postgres` (`postgres:16-alpine`) pe gazda primară DigitalOcean `ronor-sovereign` publică portul 5432 pe `0.0.0.0`. IP public: 165.245.248.223.

Verificare, la nivel de protocol. `SSLRequest` → răspuns **N (TLS indisponibil)**. `StartupMessage` pentru utilizatorii `ronor` și `postgres` → **cerere de autentificare SASL/SCRAM**. Nicio parolă transmisă, nicio dată citită.

Verificate ca **filtrate corect** pe aceeași gazdă: 6379 (Redis), 6333 (Qdrant), 3000 (aplicația).

Impact. Baza conține datele operaționale ale planurilor R-*. `r_execute_log`, `r_monitor_alerts`, `r_monitor_health`, `r_schedule_log`. Autentificarea SCRAM-SHA-256 este activă, deci nu există acces liber la date. Rămân: suprafață de atac prin forță brută, amprentare de versiune, și **trafic în clar** — inclusiv schimbul SCRAM și rezultatele interogărilor, fără TLS.

Cauză. Identică cu C-01: regulă `ufw` absentă, expunere prin lanțul `DOCKER`.

Remediere. `0.0.0.0:5432:5432 → 127.0.0.1:5432:5432`. Suplimentar, recomand activarea TLS pe conexiunile Postgres, chiar și după închiderea portului.

C-03 — Ocolirea ufw de către Docker este sistemică (CRITICĂ)

Situația de fapt. C-01 și C-02 nu sunt incidente izolate. Sunt **două manifestări ale aceluiași defect de configurare, pe două gazde diferite, descoperite independent**. În ambele cazuri `ufw status` prezintă o politică restrictivă corectă, iar portul este totuși accesibil, pentru că `docker-proxy` scrie direct în lanțul `DOCKER`.

Pe a treia gazdă, Hetzner, nu s-a găsit nicio expunere echivalentă — dar nu din cauza firewall-ului. Toate cele 55 de containere leagă porturile explicit pe `127.0.0.1`. **Curățenia Hetzner rezultă din disciplină de configurare, nu din apărare de rețea.** Aceeași disciplină aplicată corect pe două gazde și incorect pe celelalte două.

Impact. `ufw status` **nu este o sursă de adevăr** pentru expunerea de rețea pe niciuna din gazdele acestui estate. Orice audit viitor care se bazează pe el va rata expuneri reale. Orice container viitor publicat fără prefix `127.0.0.1` va fi expus silențios.

Remediere, în trei părți:

- Imediat** — remedierea C-01 și C-02.
- Structural** — dezactivarea manipulării `iptables` de către Docker (`{"iptables": false}` în `/etc/docker/daemon.json`) cu reguli de forwarding gestionate explicit; **sau**, mai simplu și mai robust, adoptarea convenției absolute că **orice** mapare de port din orice fișier `compose` poartă prefixul `127.0.0.1`, fără excepție.
- Verificare** — un script de audit care enumeră toate mapările publicate pe toate gazdele și semnalează orice legare care nu e pe `loopback`. Adăugat în CI sau ca sarcină recurentă.

C-04 — Execuție de shell neguvernată pe două gazde (ÎNALTĂ)

Situația de fapt. Două componente execută comenzi arbitrare complet în afara mecanismelor de guvernare implementate în `src/runtime/`:

Componentă	Ce expune	Context de execuție
<code>ronor-tools-gateway</code> (Hetzner, :8400)	uneltele <code>execute_shell</code> și <code>execute_on_contabo</code>	container
<code>ronor-pool.service</code> (Hetzner, systemd)	„agenți care execută sarcini autonom”	root pe gazdă

Niciuna nu trece prin poarta MI9, prin pașapoartele de agent cu listă albă de unelte, sau prin lanțul de audit — toate implementate, testate și funcționale în cod.

Impact. Aceasta este cea mai mare inconsistență dintre ce a fost construit și ce este efectiv protejat. Execuție arbitrară pe două gazde, fără mandat, fără plafon de confidențialitate și fără urmă de audit — în timp ce runtime-ul care ar putea impune toate trei nu e desfășurat.

Remediere. Rutarea ambelor componente prin poarta de guvernare existentă. Nu necesită cod nou: mecanismele există în `src/runtime/agents/tools.ts` (aplicarea listei albe în afara modelului, liniile 386–407) și în lanțul de audit. Necesită conectare și desfășurare. Ca măsură intermediară, imediată: restrângerea `ronor-pool.service` la un utilizator non-root.

C-08 — Scanarea de secrete în CI este neblokantă (ÎNALTĂ)

Situația de fapt. `.github/workflows/ci.yml`, linia 71: pasul TruffleHog are `continue-on-error: true`.

Impact. Un secret verificat, comis în istoric, produce un CI **verde**. Controlul există formal, dar nu are efect de blocare. Coroborat cu faptul că `main` are un singur `CODEOWNER`, care este și autorul a 117 din 167 de commit-uri, nu există al doilea prag de reținere.

Remediere. Eliminarea `continue-on-error: true` și rularea scanării o dată pe istoricul complet înainte de a face pasul blokant, pentru a nu bloca CI pe descoperiri preexistente.

C-13 — Nod în tailnet fără acces și fără funcție (MEDIE)

Situația de fapt. `do-bastion-agent / 100.77.197.28`, online în tailnet. Caracterizat din exterior:

- Porturi deschise: **exclusiv 22 și 80**. Închise: 443, 3000, 5432, 6333, 6379, 8080, 9090, 11434.
- Portul 80 servește **pagina implicită „Welcome to nginx!”** — server web instalat, neconfigurat, fără aplicație.
- SSH acceptă `publickey,password`. Ambele chei din estate — `id_ed25519` (SHA256:nmSgaPy...) și `ronor_git` (SHA256:AEqKh1Lj...) — respinse. Respinși și utilizatorii `root`, `ubuntu`, `admin`, `debian`, `agent`, `bastion`.

Impact. Un nod la care nu există acces, fără funcție identificabilă, cu autentificare prin parolă activată pe SSH, membru al rețelei private care conține toate gazdele de producție. Nu ascunde servicii — dar reprezintă suprafață fără contrapartidă.

Remediere. Ștergerea nodului, sau scoaterea din tailnet, sau — dacă se dorește păstrarea — recuperarea cheii din consola DigitalOcean, dezactivarea autentificării prin parolă și documentarea rolului. Recomand prima variantă.

4. Constatări de coerență a sistemului

C-05 — Cod desfășurat fără trasabilitate git (ÎNALTĂ)

Locație	Stare git	Consecință
<code>/opt/ronor-governance/app_k9</code> (Hetzner)	fără git	codul din producție al guvernării este netrasabil
<code>/opt/ronor</code> (Hetzner)	git prezent, <code>ca392ef</code> (9 aug), remote = NONE	nu se poate corela cu depozitul

Locație	Stare git	Consecință
/opt (Hetzner), 28 de directoare	neversionat	inclusiv 14 G în <code>ronor-backups</code>

Impact. La întrebarea „ce commit rulează în producție pe Hetzner?” nu există răspuns verificabil. Orice investigație de incident pornește de la zero.

Remediere. Punerea sub git cu remote corect, sau reconstrucția din `main` și înlocuirea. Până atunci, gazda Hetzner trebuie tratată ca având cod de origine necunoscută.

C-06 — Producția rulează o ramură de fix, nu `main` (ÎNALTĂ)

Situația de fapt. Pe gazda primară DigitalOcean, `/opt/ronor/app` este un clone git corect: origin `github.com/Constantin1968/RONOR-.git`, arbore curat. Însă HEAD este `6a50a7e` (19 august, AMB, „fix(ci): parse Jest failures from summary only”), pe ramura `fix/release-readiness-conf5` — cu aproximativ 25 de commit-uri în urma `origin/main`.

Suplimentar, **trei versiuni coexistă în același proces**: endpoint-ul `/health` raportează `1.0.0`, `package.json` din container declară `2.0.0-build-week`, iar imaginea este etichetată `ronor:main-327a037`.

Remediere. Stabilirea și documentarea reviziei de producție intenționate, apoi alinierea. Aceasta este o decizie care îți aparține — nu am modificat nimic.

C-07 — Modul cu răspunsuri simulate montat pe API-ul public (ÎNALTĂ)

Situația de fapt. `src/index.ts`, liniile 249–251, montează modulul moștenit la calea `/api/v1/model-exchange`. Acest modul conține `executeSimulatedProvider` (`src/model-exchange/engines.ts`, liniile 131–158); furnizorii Mistral și Qwen returnează **întotdeauna** răspunsuri simulate (liniile 230–237).

Prin contrast, runtime-ul de generația a treia nu conține nicio simulare: `grep -rn "simulated: true\\|Math.random()" src/runtime` returnează **zero** rezultate.

Impact. Un apelant pe calea moștenită primește text generat local, prezentat ca răspuns de model. Risc reputațional direct, fără beneficiu — modulul nu este necesar.

Remediere. Demontarea rutei. Aproximativ 30 de minute, inclusiv verificarea că nimic nu depinde de ea.

C-09 — „Net verified gain” nu se calculează (MEDIE, dar blocantă comercial)

Situația de fapt. Registrul de valoare **există**: tabela `runtime_value` (`src/runtime/ledgers/schema.ts`, liniile 103–122) și endpoint-ul `/ledger/value`. Însă câmpul `verified_confidence` este scris `null` în `src/runtime/api/pipeline.ts`, liniile 358 și 392, cu `confidenceMeasured: false`.

Impact. Aceasta este **singura dependență funcțională reală a pilotului OSaaS**. Modelul comercial se sprijină pe capacitatea de a demonstra câștig verificat; infrastructura de contabilizare e construită, măsurătoarea nu e cablată.

Remediere. Cablarea măsurării încrederii în pipeline. Estimat 2–4 ore. Recomand prioritizarea în raport cu termenul de 30 septembrie.

C-12 — Stiva de automatizare rulează dublu (MEDIE)

Situația de fapt. Aceleași șapte servicii de automatizare rulează pe **ambele** gazde principale, din revizii diferite:

Gazdă	Imagini	Vechime	Stare
DigitalOcean	<code>*:main-ee5c1d4</code>	3 zile	toate sănătoase
Hetzner	<code>*:local</code> , construite 24 aug 16:15	40 min – 8 h	toate sănătoase, 0 restarturi

Nu există document care să stabilească instanța autoritativă.

Remediere. Decizie explicită și documentată privind gazda autoritativă; oprirea celeilalte sau declararea explicită a rolului ei (rezervă, test).

5. Constatări privind trasabilitatea contribuției

C-11 — Trasabilitatea contribuției AI nu există în artefacte (MEDIE)

Aceasta este constatarea care răspunde direct la preocuparea privind utilizarea a mai multor agenți de pe mai multe conturi.

Situația de fapt, măsurată:

- **Un singur trailer Co-authored-by în 167 de commit-uri**, iar acesta numește identitatea de serviciu locală `RONOR Ops <ops@ronor.local>` (commit `44f3798`, PR #25). **Zero** trailere `Generated with, Co-Authored-By: Claude` sau `Co-Authored-By: Codex`.
- Căutarea termenului „codex” în mesajele de commit produce 22 de potriviri: **1 trailer real, 1 linie de proză, 20 fals-pozitive**. Cauza: „**Codex**” este numele unui serviciu al propriei arhitecturi — containerul `codex-verifier`, portul 3002, trei secrete dedicate (`codex_api_key`, `codex_verifier_token`, `codex_receipt_private_key`), cheie de semnare `Ed25519`, tip de actor în modelul de misiune. **Orice audit care caută cuvântul „codex” va supraestima masiv atribuirea AI.**
- **Atribuirea reală există exclusiv în proză, într-un singur loc precis:** `DEVPOST_SUBMISSION.md`, linia 53 — declarația că Codex a scris prima versiune a pipeline-ului de orchestrare, implementarea de scoring a routerului, calea de `append/verify` a lanțului de audit și majoritatea UI-ului de operator, cu revizuire umană a fiecărui fișier. Corelat cu inventarul de cod, zona acoperă `src/orchestrator.ts` (156 linii), `src/model-exchange/` (1.406 linii), `src/runtime/router/scoring.ts`, `src/audit/hash-chain.ts` (345 linii) și `web/` (9 fișiere) — **epoca 19–21 iulie, nu programul de automatizare din august.**
- **Manus: două apariții, zero cod atribuit.** `AMB_BUILD_NOTES.md`: 14 documentează `OPENAI_API_BASE=https://api.manus.im/api/llm-proxy/v1` — singura dovadă operațională de utilizare, ca gateway de modele în construcțiile din 3 august. `docs/executive-automation.md`: 329 conține interdicția datată: „Manus rămâne amânat până după 26 august 2026; nicio credențială sau cale de execuție Manus nu e activată.”
- **Dovada de utilizare Codex cerută de regulamentul concursului nu a fost niciodată completată** — `DEVPOST_SUBMISSION.md`: 97 conține încă placeholder-ul `[session ID from /feedback – added at submission]`.

Concluzia relevantă pentru solicitant. Utilizarea a mai multor agenți, de pe mai multe conturi, **nu a produs dezordine în cod**. Depozitul este coerent, are un singur proprietar tehnic și nu conține muncă pierdută sau contradictorie. Ce s-a pierdut este **trasabilitatea**: nu se poate demonstra, din artefacte, ce a generat care agent, de pe care cont, în care sesiune.

Remediere. Trasabilitatea retroactivă este **parțial irecuperabilă** — istoricul git nu poate fi rescris fără a invalida etichetele și dovezile de integritate existente. Ce se poate face:

1. **Recuperabil din afara depozitului** — istoricul sesiunilor din consolele OpenAI, corelat cu datele commit-urilor. Necesită acces la consolă, exclus prin constrângerea 1.3.
2. **De aplicat de acum înainte** — convenție de trailer `Co-authored-by` pentru fiecare contribuție generată, cu identificarea agentului și a contului. Aplicabilă printr-un hook de commit.
3. **Imediat, fără cost** — completarea unui `ATTRIBUTION.md` care consolidează, într-un singur loc versionat, ceea ce acum e împrăștiat în șase documente de proză. Aceasta este forma corectă de declarație pentru un audit extern.

C-18 — Absența .mailmap (SCĂZUTĂ)

Situația de fapt. 167 de commit-uri, **10 identități distincte de autor, 2 persoane reale**:

Persoană	Commit-uri	Nume de afișare	Adrese
Constantin Liviu NITA	117	5 („Constantine Liviu NITA”, „Merlin the Ancient Architect”, „Constantin Liviu NITA (Merlin)”, „Constantin1968”, „Constantin Liviu NITA”)	3
Persona „AMB”	47	3	3 (amb@, office@, constantine@mayleven.com)

Persoană	Commit-uri	Nume de afișare	Adrese
„RONOR Ops” (serviciu)	1	1	1

Adresa `office@mayleven.com` este folosită de **ambele** persoane. Nu există `.mailmap`.

Impact. Orice statistică de contribuție pe acest depozit este incorectă, inclusiv cele generate de GitHub.

Remediere. Un fișier `.mailmap` care mapează cele 10 identități pe 2 persoane plus identitatea de serviciu. 15 minute, fără rescrierea istoricului.

6. Constatări privind procesul și documentația

C-10 — Versionare fără sursă unică de adevăr (MEDIE)

Sursă	Versiune declarată
<code>package.json</code>	<code>2.0.0-build-week</code>
<code>RELEASE_MANIFEST.md</code>	<code>0.4.0-core-active</code>
Ultima etichetă git	<code>v0.5.0-20260819</code>
Cea mai mare etichetă	<code>v2.1.0-baseline</code>
Endpoint <code>/health</code> (producție)	<code>1.0.0</code>

Numerotarea scade în timp: `v2.1.0` pe 1 august, `v0.4.0` pe 3 august. `generate-checksums.sh` citește din `package.json`, deci artefactele de release purtă eticheta unei serii abandonate. `RELEASE_MANIFEST.md` fixează un „Release commit” (`bbed8343`) **diferit** de commit-ul etichetei pe care o descrie (`57f4379`) — manifestul nu este verificabil.

Remediere. Alegerea unei serii unice (recomand continuarea de la `v0.5.0`), alinierea celor cinci surse, apoi etichetarea `main` și o rulare completă a `release.yml`. Ultimul lucru important: `main` **nu a trecut niciodată prin** `release.yml` — workflow-ul se declanșează exclusiv pe etichete `v*`, iar tot kitul de activare (PR #22–#25) a intrat fără verificare de release.

C-14 — Documentație stagnantă (MEDIE)

- **43 din 47 de fișiere** `.md` neatinse din 11 august sau mai devreme.
- `CHANGELOG.md`, ultima atingere 3 august, declară în secțiunea `[Unreleased]`: „**No changes are pending**” — la aproximativ 60 de commit-uri distanță de realitate.
- `README.md` (2 august) nu menționează nicio capabilitate din ultimele trei săptămâni.
- **Întreg dosarul de dovezi atestă o stare de acum trei săptămâni:** toate cele 21 de artefacte din `evidence/knowledge/`, inclusiv `sbom.json` (2.236 linii), comise 2 august. `SBOM.json` și `checksums.sha256` nu mai corespund arborelui.
- `evidence/knowledge/fs-diff-disabled.txt` are **0 octeți**. Vidul este prin construcție dovada — dar este indistinct de o captură eșuată, și nu există atestare separată.
- **26 de fișiere de prototip arhivat** (`docs/reference/model-exchange-v0.1-original/`) și **1.647 de linii de briefuri** sunt versionate ca documentație de proiect. Prototipul este un al doilea proiect complet, cu propriul `package.json`, `render.yaml`, client React și server Express; nu compilează, nu se testează, dar intră în orice generare de checksum.
- **Cinci fișiere** `docker-compose*.yaml` **fără document de departajare**. `release.yml` împachetează doar `docker-compose.yaml` — deci configurația de automatizare, 280 de linii, cea mai recent modificată, **nu ajunge în artefactul de release**.

Remediere. O singură trecere completă: actualizarea `CHANGELOG.md`, `README.md`, `RELEASE_MANIFEST.md` și regenerarea dosarului de dovezi la revizia curentă. Estimat 1 zi. Prototipul arhivat se mută în afara arborelui versionat sau se exclude explicit din generarea de checksum.

C-15 — ESLint nu rulează în CI (SCĂZUTĂ)

`package.json` definește scriptul `lint`, `eslint.config.mjs` există, **niciun job din CI nu îl invocă**. Verificarea de tip se face doar indirect, prin `npm run build`. Suplimentar: `npm run seed` referă un fișier inexistent (`scripts/seed.ts`).

C-16 — Cod orfan și cod nemontat (SCĂZUTĂ)

825 de linii complet orfane:

Fișier	Linii
<code>src/model-exchange/engines.ts</code>	329
<code>src/persistence/memory-manager.ts</code>	222 (expune un singleton neapelat)
<code>src/scripts/provision-qdrant.ts + provision-supabase.ts</code> (duplicate)	274

Scripturile de provizionare sunt duplicate **cu implementări divergente** — `provision-qdrant.ts` verifică starea Qdrant prin `client.api('cluster').clusterStatus()` într-o copie și prin `client.versionInfo()` în cealaltă. Niciunul nu e referit din `package.json`; **nu se poate stabili din depozit care este corect**.

Separat, 2.140 de linii testate dar nemontate: puntea Telegram/Tailscale. Comentariul propriu al codului afirmă că `startTelegramBridge()` este apelată din `src/index.ts` — **apelul nu există**. Codul are teste care trec, deci CI nu semnalează. Containerul `ronor-telegram` este oprit de 2 săptămâni, deși toate cele nouă variabile Telegram sunt configurate în `.env.production`, inclusiv `TELEGRAM_APPROVER_USER_IDS` — un canal de aprobare umană complet configurat și inactiv.

C-17 — Coliziuni de nomenclatură și arhitectură (SCĂZUTĂ)

- **Trei orchestratoare, 891 de linii, același nume de bază:** `src/orchestrator.ts` (156), `src/decision-loop/orchestrator.ts` (351), `src/model-exchange/orchestrator.ts` (384). Toate trei referite, deci niciunul mort — dar limita de responsabilitate nu e documentată nicăieri.
- **Două suprafețe HTTP paralele cu stiluri opuse:** `/api/runtime`, servit de un singur fișier de 1.220 de linii, și `/api/v1`, servit de cinci fișiere însumând 734. Montate una lângă alta, fără document care să stabilească ce cerere aparține cărei suprafețe.
- **Termenul „router” desemnează trei concepte** în același arbore: strat HTTP, motor de selecție de model, și cod moștenit. „gateway” desemnează două. Există **două implementări de work-ledger**, 517 linii cumulat.
- **Coliziuni de nume de bază în** `src/`: `index.ts` ×12, `types.ts` ×4, `registry.ts` ×4, `policy.ts` ×3, `orchestrator.ts` ×3, `config.ts` ×3.
- **Cinci descrieri de arhitectură concurente** coexistă în `docs/`.

7. Constatări favorabile

Un raport de constatare care listează exclusiv deficiențe denaturează realitatea. Următoarele elemente au fost verificate și sunt de calitate ridicată:

1. **Izolarea de rețea a stivei de automatizare este reală, nu declarativă.** Rețelele `ronor-automation-control` și `ronor-model-egress` au `internal: true` verificat prin `docker network inspect`; containerele de lucru nu au rută spre internet, iar doar `model-egress-proxy` atinge uplink-ul. Deny-by-default este o **proprietate verificată a rețelei**. Aceasta este cea mai bine construită piesă din estate.
2. **Runtime-ul de generația a treia nu conține simulare.** `grep -rn "simulated: true\|Math.random()" src/runtime` → **zero** rezultate, în 13.114 linii. Nouă adaptoare cu apeluri HTTP reale, inclusiv o implementare nativă Anthropic.
3. **Disciplina de testare este consistentă și crescătoare.** 43 → 594 → 891 → **1.084 de teste**, urmărind codul la fiecare etapă. La revizia de referință: **56/56** suite trec, **1.084/1.084** teste trec, `tsc --noEmit` **zero erori**, **zero TODO**, **zero FIXME**, **zero „not implemented”**.

4. **Aplicarea listei albe de unelte este centralizată în afara modelului.** `src/runtime/agents/tools.ts`, liniile 386–407 și `workers.ts`, liniile 383–404: **modelul nu poate cere unelte**. Aceasta este decizia arhitecturală corectă, rar implementată corect.
5. **Igiena secretelor pe Hetzner este corectă.** 13 fișiere în `/srv/ronor/automation/secrets/`, toate `mode 640`, proprietar non-root `10001:10001`.
6. **Depozitul nu conține muncă pierdută.** 22 din 24 de ramuri remote sunt strămoși integrali ai `origin/main`. Cele două care raportează commit-uri în avans sunt instantanee pre-squash ale PR #24 și #25 — **aplicarea lor ar produce regresii** (reintroducerea SHA-ului hardcodat, eliminarea parametrizării porturilor). Zero stash-uri, zero commit-uri orfane (`git fsck vid`), zero fișiere netracked.
7. **Politicile de rutare sunt explicabile.** Unsprezece familii de reguli aplicate înaintea scoring-ului; fiecare respingere numește regula care a golit setul de candidați. Pin-ul de operator se aplică ultimul și **nu poate lărgi** setul admis.
8. **Aprobările au anti-replay real.** TTL 15 minute cu ștergere-înainte-de-execuție (`approval-settlement.ts`, liniile 66–67), legate la cheia API.

8. Plan de remediere propus

Nouă acțiuni, în ordinea recomandată. Șase sunt sub o oră.

Fază 1 — Imediat (aceeași zi)

Pas	Acțiune	Constatări	Efort
1	Închiderea celor două expuneri publice: Whisper pe Contabo și Postgres pe DigitalOcean, prin legare pe <code>127.0.0.1</code>	C-01, C-02	15 min
2	Eliminarea <code>continue-on-error: true</code> de la scanarea de secrete în CI	C-08	5 min
3	Restaurarea trasabilității codului desfășurat pe Hetzner — git cu remote, sau reconstrucție din <code>main</code>	C-05	30 min
4	Decizie privind <code>do-bastion-agent</code> : ștergere, sau scoatere din tailnet	C-13	15 min

Fază 2 — Săptămâna curentă

Pas	Acțiune	Constatări	Efort
5	Demontarea rutei simulate <code>/api/v1/model-exchange</code>	C-07	30 min
6	Cablarea <code>verified_confidence</code> — deblocarea pilotului OSaaS	C-09	2–4 h
7	Sursă unică de versiune: aliniere <code>package.json</code> / manifest / etichetă, apoi o rulare completă <code>release.yml</code>	C-10	1 h
8	Curățenie de semnal git: ștergerea celor 24 de ramuri remote inutile, sincronizarea <code>main</code> local, adăugarea <code>.mailmap</code> , crearea <code>ATTRIBUTION.md</code>	C-11, C-18	1 h

Fază 3 — Următoarele două săptămâni

Pas	Acțiune	Constatări	Efort
9a	Aducerea execuției neguverdate sub poarta existentă; măsură intermediară imediată — <code>ronor-pool.service</code> pe utilizator non-root	C-04	1–2 zile
9b	O singură hartă a estate-ului, versionată: 4 gazde, ce rulează pe fiecare, din ce revizie, cu ce expunere. Plus actualizarea completă a documentației și regenerarea dosarului de dovezi	C-14, C-12	1–2 zile

Pas	Acțiune	Constatări	Efort
9c	Script de audit de expunere pe toate gazdele, rulat recurent	C-03	2 h

Ce recomand să NU se facă acum

1. **Nu desfășurați runtime-ul de generația a treia înainte de pașii 1–5.** Este cel mai bun cod din estate și merită o desfășurare curată, nu una suprapusă peste trei generații confuze.
2. **Nu atingeți planurile Python.** Funcționează, conțin date operaționale reale și au 11 zile de uptime neîntrerupt. Sunt netestate și nedocumentate, dar constituie singura parte a sistemului care produce muncă utilă în acest moment.
3. **Nu rescrieți nimic pentru eleganță.** Toate cele 18 constatări sunt de coerență, proces sau configurare. **Arhitectura este sănătoasă.** Nu există constatare care să impună o rescriere.

9. Concluzie

Platforma RONOR este, la data auditului, un sistem funcțional și în părți importante bine construit, a cărui problemă centrală este **pierderea corespondenței dintre ceea ce a fost construit și ceea ce este cunoscut, documentat, protejat și desfășurat**.

Nu s-a constatat pierdere de muncă, nu s-a constatat cod contradictoriu, nu s-a constatat necesitatea vreunei rescrieri. S-au constatat **două expuneri publice reale**, ambele remediabile prin modificarea unei singure linii, și **o cauză sistemică comună** care le explică pe amândouă și care va genera altele dacă nu e adresată structural.

Cele 18 constatări se remediază, în întregime, în aproximativ **cinci zile-om**. Patru dintre cele mai severe se remediază în prima oră.

Anexă — surse ale constatărilor

Documentele de lucru pe care se sprijină acest raport, toate produse în cadrul aceluiși audit:

Document	Conținut
RONOR-RADIOGRAFIE-EXHAUSTIVA.md	radiografia consolidată — 4 gazde, 3 generații, plan complet
ronor-criminalistica-repo.md	criminalistica depozitului — ramuri, etichete, cod orfan, atribuire, 609 linii
ronor-capabilitati-runtime.md	capabilități verificate prin citirea <code>src/runtime</code> , 366 linii
RONOR-infrastructura-si-capabilitati-25aug2026.md	inventarul de infrastructură măsurat live

Raport întocmit 25 august 2026, ora 07:00 EEST. Toate valorile măsurate prin sondare live, interogare de protocol cu porturi de control, și citire directă a codului sursă. Nicio valoare de secret afișată. Nicio operațiune de scriere efectuată pe depozit sau pe sistemele de producție.